VEILLE TECHNOLOGIQUE

Données ADN, cybersécurité et souveraineté numérique
Le cas des tests généalogiques en France

DÉFINITIONS CLÉES

LA BIOINFORMATIQUE

C'est une discipline à l'intersection de l'informatique, des mathématiques et de la biologie ; elle désigne l'ensemble des outils et méthodes informatiques pour traiter, stocker et analyser des données biologiques, notamment des données médicales à grande échelle.

DONNÉE GÉNOMIQUE (ADN)

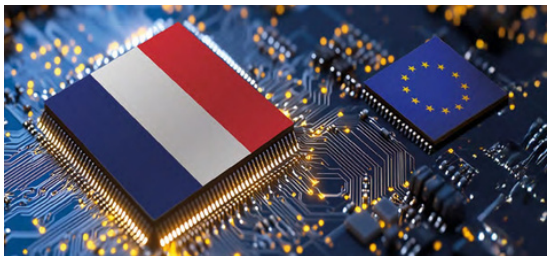
Information extraite du matériel génétique d'un individu, c'est-à-dire de son ADN.
Elle est considérée comme la donnée personnelle la plus sensible qui soit : elle est unique à chaque individu, permanente et immuable, et révèle des informations non seulement sur la personne concernée, mais aussi sur l'ensemble de sa famille biologique.

RÉ-IDENTIFICATION

Processus consistant à retrouver l'identité d'une personne à partir de données supposément anonymisées, en les croisant avec d'autres sources d'information disponibles publiquement telles que des arbres généalogiques publics, des données géographiques ou des identifiants ethniques déclarés.

SOUVERAINETÉ NUMÉRIQUE

La capacité d'un État, d'une organisation ou d'un individu à maîtriser ses données et ses systèmes d'information, sans dépendre d'acteurs étrangers ou de juridictions extérieures.



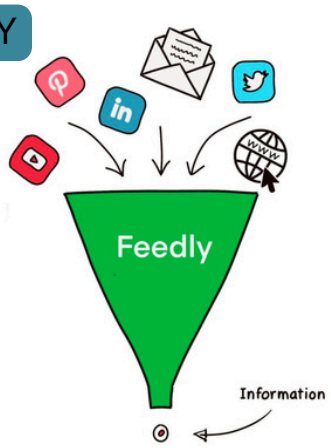
SUJET DE MA VEILLE

Pour cette année de veille, j'ai choisi de travailler sur le sujet sujet des tests ADN généalogiques et le risque qu'ils représentent en cybersécurité.
Ce sujet m'a attiré au départ pour une raison simple : j'avais vu des publicités pour ces kits sur les réseaux sociaux et je ne m'étais jamais vraiment demandé ce que devenaient les données envoyées. En creusant, j'ai découvert que la France interdisait ces tests depuis 1994, mais que des millions de Français les utilisaient quand même, et que des incidents de sécurité majeurs s'étaient déjà produits chez les principaux acteurs du marché. Le sujet mêlait à la fois du droit, de la technique et de la géopolitique, ce qui le rendait particulièrement riche à analyser.
Ce qui m'a également convaincu, c'est le lien direct avec mon option SISR. Les mêmes questions que je me pose en configurant un pare-feu ou en déployant un Active Directory; où sont les données, qui y a accès, comment sont-elles chiffrées; se retrouvent ici à une échelle critique. Sauf qu'avec des données génomiques, une fuite n'est jamais réparable.
J'ai structuré ma veille autour de trois thèmes : le cadre légal et ses limites, les incidents de sécurité documentés, et les solutions techniques émergentes.

MES OUTILS DE VEILLE

J'ai mis en place plusieurs outils complémentaires pour assurer un suivi régulier et structuré de mon sujet tout au long de l'année.

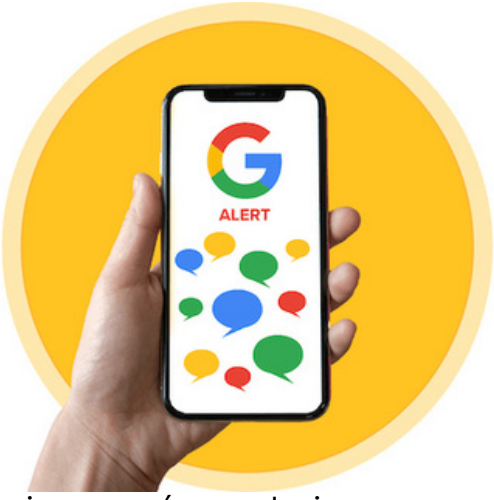
FEEDLY



Feedly est un agrégateur de flux RSS qui me permet de centraliser en un seul endroit les publications de plusieurs sources : la CNIL, l'ANSSI, des blogs spécialisés en cybersécurité et des revues juridiques traitant du RGPD. Je le consulte plusieurs fois par mois pour filtrer rapidement les informations pertinentes.

GOOGLE ALERTS

J'ai paramétré des alertes automatiques sur des mots-clés ciblés comme "fuite ADN", "ré-identification génomique", "CNIL tests génétiques" ou encore "faille zero-day santé". Cet outil m'envoie chaque semaine un récapitulatif des nouvelles publications correspondant à ces termes, ce qui me permet de ne rien manquer sans passer des heures à chercher manuellement.



En plus des informations fournies chaque semaine/mois, je me suis appuyé sur plusieurs sources complémentaires. Côté newsletters, j'ai suivi **L'Usine Digitale**, qui traite chaque semaine des nouvelles technologies qui transforment tous les pans de l'économie.
Je consulte régulièrement le **CERT-FR**, le centre gouvernemental français d'alerte aux attaques informatiques, ainsi que **CVE Details**, une base de données recensant toutes les failles de sécurité connues classées par score de criticité. Enfin, via les réseaux sociaux, sur **X**, je suis **@ZATAZ**, le compte de l'expert en cybersécurité Damien Bancal, qui a notamment documenté en détail la fuite de 23andMe et les données françaises retrouvées sur le darkweb, ainsi que **@CNIL**, qui relaie en temps réel les alertes et décisions de l'autorité française de protection des données.

THÈME 1 : LES TESTS ADN : DÉFINITION ET ENJEUX

Qu'est-ce qu'un test ADN généalogique?

Octobre 2025

Les tests ADN généalogiques sont des services vendus en kit sur internet. À partir d'un simple échantillon de salive, des entreprises comme 23andMe ou MyHeritage fournissent un rapport sur les origines ethniques et les correspondances génétiques. Apparus dans les années 2010, ces kits ont connu un regain massif en 2024 lorsque le filtre #DNATestFilter est devenu viral sur TikTok, poussant des milliers d'utilisateurs à commander de vrais kits après avoir joué avec le filtre. Ce que la plupart ignoraient, c'est qu'ils confiaient ainsi la donnée personnelle la plus sensible qui soit : unique, permanente et impossible à modifier en cas de fuite.

Source : CNIL — @CNIL sur X

Une donnée pas comme les autres

Octobre 2025

Un profil ADN révèle des données sur toute la famille biologique : frères, sœurs, parents, enfants, y compris les membres qui n'ont jamais consenti à partager quoi que ce soit. Contrairement à un mot de passe, il est impossible de le changer en cas de compromission. La divulgation de ces données peut entraîner des discriminations graves de la part d'assureurs ou d'employeurs. La CNIL l'affirme clairement dans son alerte de 2024 relayée par l'Usine Digitale : ces données sont dites "pluripersonnelles", car elles concernent bien au-delà de la seule personne ayant effectué le test.

Source : Usine Digitale — @CNIL sur X

Un cadre légal strict mais largement contourné

Decembre 2025

En France, les tests génétiques récréatifs sont interdits depuis 1994 par l'article 16-10 du Code civil. Malgré cela, de nombreux Français continuent de commander leurs kits via des services de réexpédition étrangers, phénomène amplifié par la viralité de TikTok en 2024. Les données envoyées à des sociétés comme MyHeritage — entreprise israélienne séquençant les échantillons aux États-Unis — échappent au contrôle du RGPD, car elles sont stockées hors de l'Union européenne. L'Usine Digitale a documenté que ni la CNIL ni le RGPD ne peuvent exercer de contrôle effectif sur ces serveurs étrangers.

Source : Usine Digitale — legifrance.gouv.fr

THÈME 2 : DES INCIDENTS AUX CONSÉQUENCES MASSIVES

23andMe: credential stuffing et effet de propagation

Fevrier 2026

En 2023, des pirates ont utilisé une technique de « credential stuffing » pour accéder à 14 000 comptes 23andMe. Grâce à la fonctionnalité de partage automatique entre proches génétiques, cette intrusion a exposé les données de 6,9 millions de personnes. Les données ont été triées par origine ethnique et vendues sur BreachForums. En mars 2025, 23andMe a déposé le bilan et sa base de données génétiques a été mise en vente soulevant une vague d'inquiétudes relayée par France Info et @ZATAZ sur X, qui confirme que 12 175 Français étaient concernés.

Source : France Info et relayé par @ZATAZ sur X

MyHeritage : 92 millions de comptes et un hachage obsolète

Fevrier 2026

En 2018, MyHeritage a subi une fuite touchant plus de 92 millions de comptes. Les mots de passe étaient protégés par un algorithme de hachage obsolète, vulnérables aux attaques par dictionnaire et brute force, faille référencée dans l'OWASP Top 10 et CVE Details. L'Usine Digitale a rapporté que les conditions générales de MyHeritage étaient floues sur l'utilisation des données, et que la société se réservait le droit de les conserver "aussi longtemps qu'elle l'estime nécessaire".

Ce cas m'a permis de faire le lien avec la sécurisation d'un annuaire Active Directory.

Source : Usine Digitale — CVE Details

Des failles classiques, des conséquences inédites

Mars 2026

Ce qui distingue ces incidents des fuites classiques, c'est l'irréversibilité du dommage. Lors de la faillite de 23andMe en mars 2025, France Info rapportait que la CNIL recommandait d'effacer ses données en urgence, mais que les serveurs étaient gelés et les requêtes inaccessibles. @ZATAZ sur X confirmait que la base de données était apparue sur le darkweb dès février 2025.

Ces incidents prouvent que négliger les fondamentaux type MFA, hachage, segmentation, peut avoir des conséquences permanentes et irréversibles sur des millions de personnes.

Source : France Info relayé par @ZATAZ sur X
Également trouvé sur Usine Digitale

THÈME 3 : SOLUTIONS TECHNIQUES POUR PROTÉGER LES DONNÉES GÉNOMIQUES

2MFA, hachage fort et segmentation réseau

Fevrier 2026

Les incidents de 23andMe et MyHeritage auraient pu être largement limités par des mesures de cybersécurité fondamentales. L'activation du MFA par défaut aurait bloqué les attaques par credential stuffing. Un hachage robuste avec bcrypt et salage aurait rendu inutilisables les mots de passe volés. Une segmentation stricte des accès aurait empêché l'effet de propagation. Ces trois principes sont directement liés aux compétences SISR : gestion des identités (IAM), cloisonnement réseau avec pfSense, politique de mots de passe dans Active Directory.

Source : CERT-FR — OWASP Top 10

Chiffrement homomorphe et federated learning

Fevrier 2026

Pour les données les plus sensibles, des solutions plus avancées émergent. Le chiffrement homomorphe permet d'effectuer des calculs sur des données chiffrées sans jamais les déchiffrer, réduisant la surface d'attaque. Le federated learning permet d'entraîner des modèles d'IA localement, sans centraliser les données sur un seul serveur. La CNIL recommande d'ailleurs cette approche pour les bases de données médicales, et l'Usine Digitale souligne que ces techniques représentent l'avenir de la protection des données de santé à grande échelle.

Source : Usine Digitale — @CNIL sur X

Privacy by design : sécuriser dès la conception

Mars 2026

Ces solutions illustrent toutes le même principe : le "privacy by design", intégrer la sécurité dès la conception du système et non après coup. Les données synthétiques générées par IA permettent de reproduire les propriétés statistiques d'une population sans exposer aucun individu réel. Pour un futur technicien SISR, ce principe s'applique à chaque projet : une architecture sécurisée dès le départ coûte toujours moins cher qu'une correction après une fuite; une leçon que 23andMe a apprise à ses dépens, documentée par France Info lors de sa liquidation en 2025.

Source : France Info — CNIL